

```
PS C:\Users\cidco> docker scout cves docker.io/httpd
  New version 1.18.4 available (installed version is 1.18.3) at https://github.com/docker/scout-cli
  SBOM obtained from attestation, 168 packages found
  Provenance obtained from attestation
  x Detected 16 vulnerable packages with a total of 33 vulnerabilities

## Overview
```

	Analyzed Image
Target	httpd:latest
digest	2fe8d2c5afb9
platform	linux/amd64
provenance	https://github.com/docker-library/httpd.git
vulnerabilities	684a447a23a8035356d5c4e2e1f85212cfd39a3
size	45 MB
packages	168
Base image	oisupport/staging-amd64:6ffd007f3981b8aa686481437ba6e2bfe4311ab77274ba1691ecc9765babb43bae614fe11cb3

```
## Packages and Vulnerabilities
0C 1H 0M 1L libxml2 2.12.7+dfsg+really2.9.14-2.1+deb13u1
pkg:deb/debian/libxml2@2.12.7+dfsg%2Breally2.9.14-2.1%2Bdeb13u1?os_distro=trixie&os_name=debian&os_version=13
2.4/Dockerfile (31:226)
RUN set -eux; \
  \
  # mod_http2 mod_lua mod_proxy_html mod_xml2enc
  # https://anonscm.debian.org/Cgit/pkg-apache/apache2.git/tree/debian/control?id=adb6f181257af28ee67af15fc49d2699a0080d4c
  savedAptMark="$(apt-mark showmanual)"; \
  apt-get install --update -y --no-install-recommends \
  bzip2 \
```

Figure 3: Output of `docker scout cves`

```
docker scout cves --only-severity
critical --only-vuln-packages
<image:tag>
```

You can also export these results to structured formats like SARIF for integration with other tools.

Interpreting vulnerability reports: Severity vs CVSS

Understanding how Scout ranks vulnerabilities is crucial. Docker Scout aggregates data from multiple advisory sources but prioritises the severity rating from the package's maintainer. For example, for an OS package in a Debian image, the severity assigned by the Debian security team is prioritised over a generic CVSS score from a national database. This can sometimes lead to a confusing result, but this is by design.

For instance, you might see a vulnerability rated 'LOW' severity but with a 9.8 (Critical) CVSS score. This happens when the preferred advisory (e.g., the OS maintainer) rates the vulnerability as LOW but doesn't assign a CVSS score. Docker Scout will then also display the CVSS score from a fallback advisory, which might be 9.8.

Scout's official severity rating, however, will correctly reflect the preferred source's LOW assessment.

Vulnerabilities that have no CVSS score in any source are marked as 'Unspecified' (U). Most advisories follow the standard CVSS v3.0 mapping:

CVSS score	Severity rating
9.0 – 10.0	Critical (C)
7.0 – 8.9	High (H)
4.0 – 6.9	Medium (M)
0.1 – 3.9	Low (L)

Getting started: Activation and limits

To activate Docker Scout:

- You must have an *Editor* or *Owner* role in your Docker organisation.
- Docker Hub repositories are integrated by default, but third-party registries must first be integrated with your Docker organisation.

- Go to *Repository settings* in the Docker Scout dashboard, select your repositories, and click on *Enable image analysis*.

Subscriptions and limits of Docker Scout are:

- The 'Docker Personal' plan includes one Scout-enabled repository. You can upgrade your subscription for additional repositories.
- Image analysis (both on the platform and via Docker Desktop's background indexing) has a maximum image size of 10GB.
- This limit is waived for images that are pushed with an SBOM attestation (using the `--sbom=true` flag).

By saving image metadata and constantly recalibrating against new threat intelligence, Docker Scout ensures your security posture is always up-to-date, giving you the power to find and fix vulnerabilities before they become critical problems. **END** 🐧

By: Ashutosh S. Bhakare

The author has 25+ years of experience as a corporate trainer and consultant. He is Docker Captain, Google authorised trainer, Red Hat Certified Instructor and CEO of Unnati Development and Training Centre Pvt Ltd.